

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM SISTEMAS DE INFORMAÇÃO

LEONARDO FELIX RIBEIRO FAIS
LUCAS ROBERTO DA SILVA MORAIS

PROJETO CONTINUUM

MOGI DAS CRUZES

2026

LEONARDO FELIX RIBEIRO FAIS
LUCAS ROBERTO DA SILVA MORAIS

PROJETO CONTINUUM

Trabalho apresentado a Universidade de Mogi das Cruzes como requisito parcial de avaliação da disciplina Políticas de Segurança da Informação

Orientador: Prof. Dr. Fabiano B. Menegidio

MOGI DAS CRUZES

2026

RESUMO

O presente trabalho tem como objetivo desenvolver uma solução tecnológica, denominada Projeto Continuum, destinada a otimizar o processo de passagem de plantão entre profissionais de saúde, visando mitigar falhas de comunicação e reduzir a ocorrência de erros na assistência médica. Trata-se de uma pesquisa aplicada e de produção tecnológica, desenvolvida na Universidade de Mogi das Cruzes (UMC), estruturada em quatro etapas: mapeamento dos fluxos críticos de comunicação na transição do cuidado, definição dos requisitos funcionais de segurança e das restrições legais estabelecidas pela Lei Geral de Proteção de Dados Pessoais (LGPD), concepção da arquitetura web e implementação e validação do sistema. A solução foi estruturada com tecnologias web, banco de dados relacional, controle de acesso baseado em papéis e mecanismos de validação para proteção de informações clínicas sensíveis. Como resultados, destaca-se a obrigatoriedade do preenchimento de informações críticas, como sinais vitais e medicações pendentes, além da utilização de registros de auditoria com identificação de autoria e carimbo de tempo, mecanismos de exclusão lógica para preservação do histórico clínico e módulo destinado à gestão de consentimentos dos pacientes. Conclui-se que o Projeto Continuum contribui para a padronização e rastreabilidade da passagem de plantão, estabelecendo um meio auditável para apoiar a continuidade da assistência. Como trabalhos futuros, propõe-se a expansão da prototipação para dispositivos móveis e a realização de testes de usabilidade com equipes médicas, visando adequar a solução às demandas da rotina hospitalar.

Palavras-chave: passagem de plantão; continuidade do cuidado; segurança da informação; LGPD; tecnologia em saúde.

SUMÁRIO

1. ESPECIFICAÇÃO DE ENGENHARIA DE SOFTWARE (SRS / ERS)	1
1.1 Declaração e Delimitação de Escopo	1
1.2 Requisitos Funcionais (RF)	2
1.3 Requisitos Não Funcionais de Usuário (RNFU)	3
1.4 Regras de Negócio (RN)	3
1.5 Casos de Uso de Engenharia de Software	4
2. ENGENHARIA DE SEGURANÇA DA INFORMAÇÃO & CRIPTOGRAFIA	6
2.1 Gestão de Credenciais e Chaves	6
2.2 Criptografia em Repouso e Gestão de Chaves	7
2.3 Trânsito Seguro	8
3. GOVERNANÇA E CONFORMIDADE COM A LGPD	8
3.1 Tabela de Mapeamento de Dados (RoPA)	8
3.2 Matriz dos Direitos do Titular	10
4. MODELAGEM DE AMEAÇAS E AUDITORIA IMUTÁVEL	10
4.1 Matriz de Riscos e Contramedidas (STRIDE)	10
4.2 Estrutura de Auditoria	11
5. DOCUMENTAÇÃO TÉCNICO-CIENTÍFICA GERAL	11
5.1 Visão Geral e Arquitetura	11
5.2 Validação e Testes	13
5.3 Referencial Teórico	16

1. ESPECIFICAÇÃO DE ENGENHARIA DE SOFTWARE (SRS / ERS)

Delimitação estrutural fundamentada nas normativas de segurança e pilares da Tríade CIA, voltada ao cumprimento das metas técnicas do projeto

1.1 DECLARAÇÃO E DELIMITAÇÃO DE ESCOPO

Objetivo Geral: Desenvolver uma solução tecnológica estruturada, denominada Projeto Continuum, para otimizar o processo de passagem de plantão entre profissionais de saúde, mitigando falhas de comunicação e reduzindo a incidência de erros médicos. A plataforma visa o gerenciamento de acesso a dados clínicos e prontuários por meio de autenticação multifatorial, rigor criptográfico e conformidade regulatória.

- **Escopo Positivo (In-Scope):**

1. Módulo de Autenticação e Credenciais com hash robusto, salt único, 2FA mandatória pós-autenticação primária, tempo de expiração de sessão, logout com revogação e rate limiting.
2. Módulo de Recuperação de Senha com tokens efêmeros de uso único, tratamento de erros e trilha de auditoria.
3. Módulo de Criptografia e Trânsito com conexão HTTPS/TLS 1.3 obrigatória e cifragem simétrica (AES-256) de dados sensíveis em repouso.
4. Módulo de Conformidade com a LGPD com coleta e revogação de consentimento, consulta a dados, exportação (portabilidade) e exclusão/anonimização do titular.
5. Subsistema de Auditoria com geração de logs imutáveis de eventos de login, falhas, 2FA e requisições de titulares.
6. Interface de controle de acesso clínico baseado em papéis (RBAC) para garantir apenas profissionais autorizados acessem dados sensíveis dos pacientes durante a utilização do sistema.
7. Artefatos Científicos com elaboração de documentação técnico-científica, resumo estruturado (200-300 palavras) e pôster científico com apresentação oral.

- **Escopo Negativo (Out-of-Scope):** Sistemas de faturamento contábil/financeiro; autenticação por redes sociais (OAuth com terceiros); infraestrutura física redundante de datacenters; controles de estoque; sistemas de folha de pagamento; integração imediata com sistemas de outros setores, máquinas ou equipamentos hospitalares;

1.2 REQUISITOS FUNCIONAIS (RF)

Código	Categoria	Descrição Comportamental Detalhada	Item do Checklist
RF-01	Autenticação e Gestão de Credenciais	O sistema deve capturar a palavra-passe do profissional de saúde, derivar um salt exclusivo e persistir o hash associado, validando as credenciais no login	Item 1.1, 1.3, 1.4, 1.7
RF-02	Autenticação de Dois Fatores (2FA)	O sistema deve exigir e validar o código 2FA exclusivamente após o sucesso do primeiro fator, libertando a sessão completa apenas após esta validação secundária.	Item 1.5, 1.6
RF-03	Gestão de Sessão e Logout	O sistema deve expirar a sessão após um período de inatividade configurado e invalidar imediatamente o token de sessão ao acionar o logout.	Item 1.9, 1.10
RF-04	Recuperação de Palavra-passe	O sistema deve gerar um token criptograficamente seguro com tempo limite de expiração para a recuperação de credenciais, invalidando-o imediatamente após o uso com sucesso ou rejeitando tokens expirados	Item 2.1, 2.2, 2.3, 2.4, 2.5
RF-05	Gestão de Consentimento LGPD	O sistema deve recolher o consentimento explícito associado à finalidade clínica, registrando a data, hora e versão do termo, além de permitir a sua revogação	Item 4.4, 4.5, 4.6, 4.7
RF-06	Exercício de Direitos do Titular	O sistema deve disponibilizar um painel acessível para o titular visualizar os dados sob custódia, permitir a exportação em formato estruturado e solicitar a eliminação dos dados, ressalvadas as guardas legais.	Item 4.8, 4.9, 4.10
RF-07	Cadastro e Validação de Perfis	O sistema deve registrar pacientes e médicos, executando a validação obrigatória de formato de credenciais (CRM/UF) e bloqueando duplicidades de e-mail no ato do registro.	Item 1.8, 6.4
RF-08	Controle de Acesso (RBAC)	O sistema deve restringir o acesso a informações sensíveis (prontuários e alergias) exclusivamente a usuários autenticados com perfil clínico autorizado.	Item 4.2, 4.3, 6.3

RF-09	Geração de Trilhas de Auditoria	O sistema deve gerar registros automáticos na base de dados para cada tentativa de login, falha de 2FA, reset de senha e revogação de consentimento.	Item 2.6, 2.7, 5.1, 5.2
--------------	---------------------------------	--	-------------------------

1.3 REQUISITOS NÃO FUNCIONAIS DE USUÁRIO (RNFU)

Código	Categoria	Descrição Comportamental Detalhada	Item do Checklist
RNF-01	Segurança (Hash)	O armazenamento de senhas deve utilizar algoritmo robusto de derivação (Argon2id, bcrypt ou PBKDF2) com parâmetros de custo justificados e salt mínimo de 128 bits.	Item 1.1, 1.2, 1.3
RNF-02	Segurança (Defesa)	O sistema deve mitigar força bruta por meio de Rate Limiting (bloqueio de 60 segundos após 5 requisições consecutivas inválidas)	Item 1.11
RNF-03	Confiabilidade (Logs)	Os registros de log devem ser mantidos em repositório com proteção contra alteração e exclusão acidental (append-only / imutabilidade).	Item 5.3
RNF-04	Segurança (Repouso)	Dados sensíveis armazenados em banco devem ser protegidos por cifra simétrica segura (AES-256) com isolamento das chaves criptográficas.	Item 3.4, 3.5, 3.6
RNF-05	Segurança (Trânsito)	Toda a comunicação cliente-servidor deve operar sob TLS/HTTPS com bloqueio explícito de conexões em texto claro (HTTP porta 80)	Item 3.1, 3.2, 3.3
RNF-06	Privacy by Design (Minimização)	A arquitetura de banco de dados deve separar estruturalmente os dados cadastrais (ex: nome, e-mail) dos dados sensíveis clínicos (ex: alergias, eventos adversos) para garantir a minimização nativa do acesso.	Item 4.1, 4.2, 4.3
RNF-07	Resiliência e Tratamento de Erros	O sistema deve interceptar exceções lógicas e de banco de dados (PDOExceptions), retornando respostas HTTP padronizadas (ex: 401, 500) sem expor a <i>stack trace</i> do servidor aos usuários.	Item 6.7, 6.8

1.4 REGRAS DE NEGÓCIO (RN)

Código	Categoria	Descrição Comportamental Detalhada	Item do Checklist
RN-01	Sequenciamento de Autenticação (2FA)	A validação do segundo fator (2FA) deve ocorrer estritamente após a autenticação primária (e-mail e senha) bem-sucedida. O código gerado terá validade exata de 5 minutos; caso o tempo expire, a requisição de acesso é abortada e a sessão temporária é destruída.	Item 1.5, 1.6
RN-02	Política de Bloqueio (Rate Limiting)	Como proteção contra força bruta (rate limit, bloqueio, atraso), o sistema permite um limite máximo de 5 (cinco) tentativas consecutivas de <i>login</i> falhadas. Ao atingir o limite, o IP/conta	Item 1.11

		sofre um bloqueio temporário compulsório de 60 segundos antes de aceitar novas requisições.	
RN-03	Validade e Expiração de Sessões	Por lidar com informações clínicas sensíveis, as sessões com tempo de expiração possuem uma tolerância máxima de 30 minutos de inatividade. Ultrapassado este período, o servidor deve invalidar o <i>cookie</i> e exigir nova autenticação multifatorial.	Item 1.9, 1.10
RN-04	Integridade de Cadastros Profissionais	O sistema impede a duplicidade de contas. O cadastro de perfis médicos exige a validação conjunta do número do CRM e da Unidade Federativa (UF), impedindo que o mesmo registro profissional ou o mesmo e-mail sejam cadastrados duas vezes.	Item 1.12
RN-05	Imutabilidade e Rastreabilidade	Em nenhuma hipótese o sistema permitirá a exclusão (DELETE) ou edição (UPDATE) de registros na tabela de Log de Auditoria. A infraestrutura garante a proteção contra alteração dos logs, operando em regime de inserção contínua (<i>append-only</i>).	Item 5.3
RN-06	Obrigatoriedade de Consentimento	É vedada a coleta e o processamento de dados sensíveis de pacientes que não tenham marcado a opção de aceite do termo ('sim') no formulário, garantindo o registro explícito de consentimento e resguardando a base de dados contra passivos relacionados à LGPD.	Item 4.4
RN-07	Minimização por Controle de Papéis (RBAC)	O sistema deve aplicar o princípio da minimização, garantindo que o acesso aos dados clínicos (alergias e eventos adversos) seja concedido exclusivamente para profissionais de saúde associados ao plantão ativo, bloqueando o acesso de pacientes aos prontuários de terceiros.	Item 4.3

1.5 CASOS DE USO DE ENGENHARIA DE SOFTWARE

UC-01: Autenticação de Múltiplos Fatores (2FA) Este fluxo garante que a entrada no sistema cumpra rigorosamente os parâmetros de defesa contra acessos não autorizados.

Atributo	Descrição
Ator Principal	Profissional de Saúde (Médico) e Paciente.
Pré- Condições	O usuário deve possuir um cadastro ativo e credenciais válidas no banco de dados.
Fluxo Principal	1. O usuário insere e-mail e senha no formulário de login. 2. O sistema valida as credenciais comparando o hash computado com o registro persistido. 3. O sistema gera um código de 6 dígitos, aplica hash, define expiração de 5 minutos e envia via e-mail. 4. O usuário insere o código 2FA. 5. O sistema exige e valida o código 2FA exclusivamente após o sucesso do primeiro fator, liberando a sessão completa apenas após a validação secundária.

Fluxos de Exceção	E1 (Credencial Inválida): O sistema rejeita o login, incrementa o contador e registra a falha no log de auditoria. Após 5 falhas, bloqueia o usuário por 60 segundos (Rate Limit).
	E2 (2FA Expirado/Inválido): O sistema invalida a tentativa, destrói a sessão temporária e registra o evento de segurança no log.
Requisitos	RF-01, RF-02, RNF-02, RN-01.

UC-02: Solicitação e Recuperação de Credenciais Garante que a redefinição de senhas ocorra sob um canal seguro e rastreável.

Atributo	Descrição
Ator Principal	Profissional de Saúde (Médico) e Paciente.
Pré- Condições	O usuário não consegue acessar a conta devido ao esquecimento da senha.
Fluxo Principal	1. O usuário informa o e-mail cadastrado na tela de recuperação. 2. O sistema gera token pseudoaleatório criptograficamente seguro com tempo limite de expiração e registra o pedido em log. 3. O usuário recebe o token via e-mail e o insere no sistema. 4. O usuário define uma nova senha (mínimo de 6 caracteres). 5. O sistema criptografa a nova senha (Argon2id), invalida o token imediatamente após o primeiro uso com sucesso e registra o evento.
Fluxos de Exceção	E1 (Token Adulterado/Expirado): O sistema deve validar o token de recuperação e rejeitar tokens expirados/adulterados, emitindo a falha correta para token expirado.
Requisitos	RF-04, RNF-01, RN-05.

UC-03: Exercício de Direitos do Titular (LGPD) Materializa as ferramentas de governança exigidas pela lei de proteção de dados diretamente na interface do usuário.

Atributo	Descrição
Ator Principal	Paciente (Titular dos Dados).
Pré- Condições	O paciente deve estar autenticado com a sessão válida no sistema.
Fluxo Principal	1. O paciente acessa o painel de configurações da sua conta (funcionalidade de consulta aos dados do titular). 2. O paciente aciona a funcionalidade de exportação dos dados. 3. O sistema compila as informações (nome, e-mail, telefone, endereço, histórico) e permite o download dos dados pessoais do titular em formato estruturado (JSON ou CSV). 4. O paciente aciona a exclusão da conta. 5. O sistema solicita a senha para confirmação e, após validação, deleta os registros do banco de dados, revogando os consentimentos.
Fluxos de Exceção	E1 (Senha Incorreta na Exclusão): O sistema bloqueia a exclusão da conta e gera um log de tentativa de exclusão não autorizada.
Requisitos	RF-05, RF-06, RN-06.

UC-04: Acesso ao Prontuário e Geração de Trilha de Auditoria Descreve o fluxo contínuo de rastreabilidade durante o uso clínico diário da plataforma.

Atributo	Descrição
Ator Principal	Profissional de Saúde (Médico).

Pré- Condições	O médico deve estar autenticado, com 2FA validado e possuir permissões clínicas associadas ao seu perfil (RBAC).
Fluxo Principal	1. O médico acessa a interface de passagem de plantão e clica para visualizar as informações clínicas ou alergias de um paciente. 2. O sistema valida as permissões da sessão atual (RBAC). 3. O sistema recupera os dados sensíveis protegidos. 4. Simultaneamente, o sistema gera registros de logs estruturados de acessos, inserindo na tabela Log de Auditoria o ID do médico, a ação realizada, o endereço IP e a data/hora exata do acesso.
Fluxos de Exceção	E1 (Tentativa de Alteração de Log): Caso haja qualquer tentativa de injeção ou manipulação no banco de dados para apagar o registro do acesso, a estrutura <i>append-only</i> bloqueia a ação, garantindo a proteção contra alteração dos logs
Requisitos	RF-08, RF-09, RNF-03, RN-07.

2. ENGENHARIA DE SEGURANÇA DA INFORMAÇÃO & CRIPTOGRAFIA

Detalhamento aprofundado dos controles criptográficos, operacionais e defensivos do projeto.

2.1 GESTÃO DE CREDENCIAIS E CHAVES

Parâmetro	Configuração	Justificativa Técnica de Segurança
Algoritmo	Argon2id	Algoritmo de derivação de senhas projetado para ser resistente a ataques de força bruta e ataques que exploram memória, combinando características das variantes Argon2i e Argon2d.
Custo de memória (memory_cost)	65.536 KiB (64 MiB)	Impõe custo de memória significativo a cada operação de derivação, dificultando a execução massiva de tentativas por hardware especializado. O valor foi selecionado após comparação experimental com 32, 64, 96 e 128 MiB.
Custo de tempo (time_cost)	3 iterações	Aumenta o custo computacional de cada tentativa de senha. O valor 3 apresentou equilíbrio entre custo de processamento e latência nos benchmarks realizados.
Paralelismo (threads)	2 threads / lanes	Permite paralelismo na execução do Argon2id, utilizando recursos disponíveis do processador sem elevar excessivamente o custo por operação no ambiente avaliado.
Salt criptográfico	16 bytes (128 bits), gerado automaticamente	O salt é exclusivo para cada senha e é gerado pelo mecanismo de password_hash(). Isso impede o uso eficiente de hashes pré-computados para diferentes usuários que possuam a mesma senha.
Latência de referência	128,85 ms (média)	Resultado obtido no benchmark inicial com 30 execuções. O tempo representa o custo médio de geração do hash no ambiente de desenvolvimento.
Carga sequencial	≈117–172 ms/hash	Nos testes de carga realizados com 1 a 50 operações, a configuração apresentou comportamento compatível com a capacidade do ambiente de testes.
Carga concorrente	≈146–213 ms/operação	Nos testes de concorrência com 10, 25 e 50 operações simultâneas, a configuração apresentou aumento de latência, porém sem crescimento descontrolado no ambiente avaliado.

```
// Teste de Benchmark para cada configuração de Argon2id
// O teste serve para calcular o tempo médio de hash para cada configuração,
// permitindo avaliar o impacto de diferentes parâmetros na performance do algoritmo.
$repeticoes = 50;
foreach ($configuracoes as $config) {
    $tempos = [];
    for ($i = 0; $i < $repeticoes; $i++) {
        $inicio = hrtime(true);
        password_hash(
            $senha,
            PASSWORD_ARGON2ID,
            $config
        );
        $fim = hrtime(true);
        $tempoMs = ($fim - $inicio) / 1_000_000;
        $tempos[] = $tempoMs;
    }
    $media = array_sum($tempos) / count($tempos);
}
```

```
// Benchmark para calcular tempos de carga
for ($i = 0; $i < $repeticoes; $i++) {
    $inicio = hrtime(true);
    password_hash(
        $senha,
        PASSWORD_ARGON2ID,
        $config
    );
    $fim = hrtime(true);
    $tempoMs = ($fim - $inicio) / 1_000_000;
    $tempos[] = $tempoMs;
}
sort($tempos);
$media = array_sum($tempos) / count($tempos);
$mediana = $tempos[intdiv(count($tempos), 2)];
$minimo = min($tempos);
$maximo = max($tempos);

// Desvio padrão
$soma = 0;
foreach ($tempos as $tempo) {
    $soma += pow($tempo - $media, 2);
}
$desvioPadrao = sqrt($soma / count($tempos));
```

```
// Benchmark para teste de carga, calculando o tempo médio de hash para diferentes quantidades de operações.
foreach ($quantidades as $quantidade) {
    $inicio = hrtime(true);
    for ($i = 0; $i < $quantidade; $i++) {
        password_hash(
            $senha,
            PASSWORD_ARGON2ID,
            [
                'memory_cost' => $config['memory_cost'],
                'time_cost' => $config['time_cost'],
                'threads' => $config['threads']
            ]
        );
    }
    $fim = hrtime(true);
    $tempoTotal = ($fim - $inicio) / 1_000_000;
    $tempoMedio = $tempoTotal / $quantidade;
}
```

2.2 CRIPTOGRAFIA EM REPOUSO E GESTÃO DE CHAVES

No banco de dados relacional que sustenta os registros hospitalares, é mandatório que os dados sensíveis criptografados em repouso recebam tratamento adequado para evitar o vazamento de informações clínicas.

- A plataforma implementa o uso de algoritmo criptográfico adequado, utilizando o padrão AES-256GCM para cifrar os dados médicos.
- A arquitetura garante que as chaves criptográficas protegidas fiquem isoladas, adotando o modelo de criptografia em envelope onde a Chave Mestra (KEK) nunca reside no mesmo ambiente do banco de dados.
- A tag de autenticação gerada pelo modo GCM é concatenada aos dados cifrados para impedir a alteração de prontuários de forma não autorizada.

2.3 TRÂNSITO SEGURO

Como o software web opera interfaces em linguagens web dinâmicas e transaciona dados via APIs de forma contínua, o tráfego exige que a comunicação protegida por TLS/HTTPS seja absoluta em todos os acessos.

3. GOVERNANÇA E CONFORMIDADE COM A LGPD

Esta seção descreve os mecanismos arquiteturais que garantem a aderência do sistema aos princípios da Lei nº 13.709/2018 (Lei Geral de Proteção de Dados). As funcionalidades foram estruturadas para assegurar o controle e a transparência no tratamento de informações de pacientes e profissionais da saúde.

3.1 TABELA DE MAPEAMENTO DE DADOS (ROPA)

Dado Coletado	Categoria	Finalidade Declarada	Base Legal LGPD	Controle e Retenção
Nome Completo	Cadastral	Identificação e personalização do titular	Execução de Contrato (Art. 7º, V)	Acesso restrito via RBAC; retido até término da conta

E-mail	Cadastral	Autenticação no sistema, validação 2FA e processo de recuperação de senha.	Execução de Contrato (Art. 7º, V)	Índice blindado no banco de dados; tráfego protegido por TLS (HTTPS); retido até exclusão da conta.
Telefone	Cadastral	Contato emergencial para comunicação clínica e canal de contingência para envio de alertas ou tokens de acesso.	Execução de Contrato (Art. 7º, V)	Acesso restrito via RBAC; retido até durar a vinculação do titular com a instituição hospitalar.
CPF	Cadastral	Identificação unívoca do paciente para vinculação correta ao prontuário.	Proteção da Vida ou Tutela da Saúde (Art. 11, II, 'e'/f')	Acesso restrito via RBAC. Retenção permanente segundo normas hospitalares.
Data de Nascimento	Cadastral	Identificação unívoca do paciente para vinculação correta ao prontuário.	Proteção da Vida ou Tutela da Saúde (Art. 11, II, 'e'/f')	Acesso restrito via RBAC. Retenção permanente segundo normas hospitalares.
Senha (Credencial)	Crítico / Autenticação	Validação de identidade no login	Dever de Segurança (Art. 6º, VII)	Argon2id + Salt único de 128 bits. Nunca em texto claro
Número de Registro Profissional	Cadastral / Profissional	Validação de credenciais e permissões para atuação clínica e prescrição no sistema.	Cumprimento de Obrigação Legal (Art. 7º, II)	Mantido em texto claro. Retido para arquivo histórico.
Sexo e Etnia	Sensível / Demográfico	Apoio a diagnósticos clínicos, estudos epidemiológicos e métricas de saúde.	Tutela da Saúde (Art. 11, II, 'f')	Criptografia em repouso. Acesso limitado ao corpo clínico autorizado.
Endereço	Cadastral	Composição do prontuário demográfico do paciente para eventuais notificações legais, de saúde pública ou mapeamento epidemiológico.	Cumprimento de Obrigação Legal (Art. 7º, II) ou Tutela da Saúde (Art. 11, II, 'f').	Acesso restrito às equipes administrativas e clínicas (RBAC); retenção permanente vinculada ao tempo legal de guarda do prontuário médico.
Informações Clínicas e Alergias	Sensível / Saúde	Continuidade do cuidado médico durante a passagem de plantão.	Tutela da Saúde (Art. 11, II, 'f')	Criptografado em repouso (AES-256); Acesso restrito exclusivamente à equipe clínica (RBAC).
Eventos	Sensível / Saúde	Registro de intercorrências clínicas durante o plantão para apuração e continuidade.	Tutela da Saúde (Art. 11, II, 'f') e Exercício Regular de Direitos	Tabela com rastreabilidade total (Logs). Retenção ligada ao prontuário do paciente.
Logs de Acesso e IP	Identificação Digital	Auditoria e detecção de incidentes	Cumprimento Legal (Marco Civil, Art. 15)	Retenção mínima de 6 meses; log append-only imutável.
Consentimento	Comprovação Legal	Evidenciar autorização expressa	Consentimento (Art. 7º, I)	Timestamp UTC, versão do termo e IP salvos em banco.

3.2 MATRIZ DOS DIREITOS DO TITULAR

Direito do Titular	Funcionalidade Implementada	Evidência/Endpoint
Consulta e Acesso (4.8)	Módulo do Titular; visualização clara de todos os dados cadastrados.	apps/Server/api/consultar.php
Exportação / Portabilidade (4.9)	Botão “Exportar meus dados” com geração JSON/CSV estruturado.	apps/Server/api/exportar.php
Exclusão / Anonimização (4.10)	Exclusão lógica imediata com purge definitivo e anonimização de campos.	apps/Server/api/confirmar_deleta.php
Revogação de Consentimento (4.6)	Toggle switch no perfil com registro de histórico e auditoria de revogação.	apps/Server/api/revoga_conta.php

4. MODELAGEM DE AMEAÇAS E AUDITORIA IMUTÁVEL

4.1 MATRIZ DE RISCOS E CONTRAMEDIDAS (STRIDE)

Categoria STRIDE	Ameaça Identificada	Impacto	Contramedida Implementada
Spoofing	Acesso indevido utilizando credenciais furtadas de um profissional de saúde.	Crítico	Implementação de hash criptográfico e exigência estrita de autenticação de dois fatores (2FA) após o sucesso do primeiro fator.
Tampering	Intercepção e modificação de prontuários médicos ou prescrições durante o tráfego na rede.	Crítico	Toda a comunicação opera sob TLS/HTTPS, com bloqueio automático de conexões não seguras.
Repudiation	Profissional negar ter inserido um evento adverso ou consultado o histórico de um paciente.	Alto	Registro obrigatório na tabela Log de Auditoria, capturando utilizador, IP e tabela afetada com carimbo de tempo.
Information Disclosure	Exfiltração da base de dados MySQL contendo informações clínicas e alergias dos pacientes.	Crítico	Dados sensíveis são criptografados em repouso com algoritmo criptográfico adequado (AES-256) e chaves protegidas.
Denial of Service	Ataques automatizados no painel de login visando indisponibilizar a passagem de plantões.	Alto	Proteção contra força bruta por meio da aplicação de <i>rate limit</i> , atraso ou bloqueio de requisições consecutivas

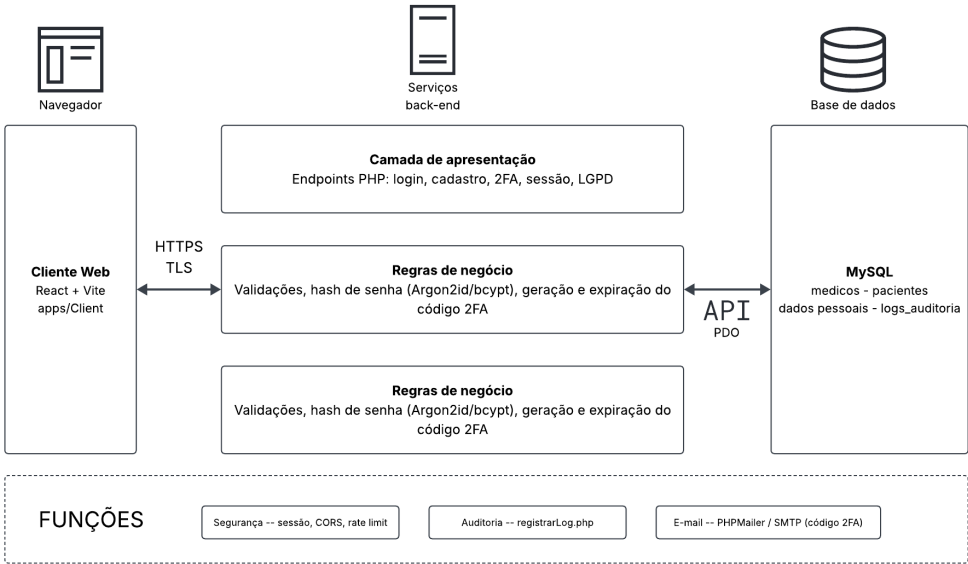
Elevation of Privilege	Usuário com perfil de médico residente acessar funcionalidades exclusivas do médico especialista.	Alto	Controle de Acesso Baseado em Papéis (RBAC) rigorosamente validado no <i>backend</i> antes de qualquer transação no banco de dados.
------------------------	---	------	---

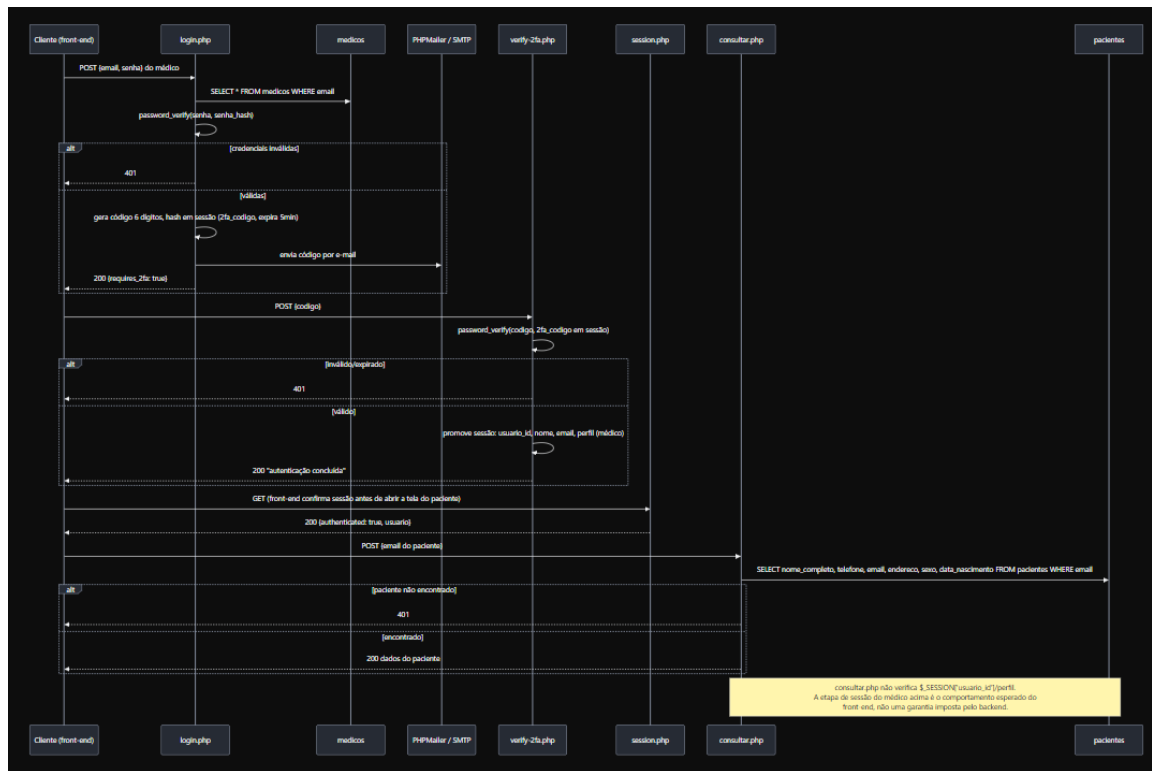
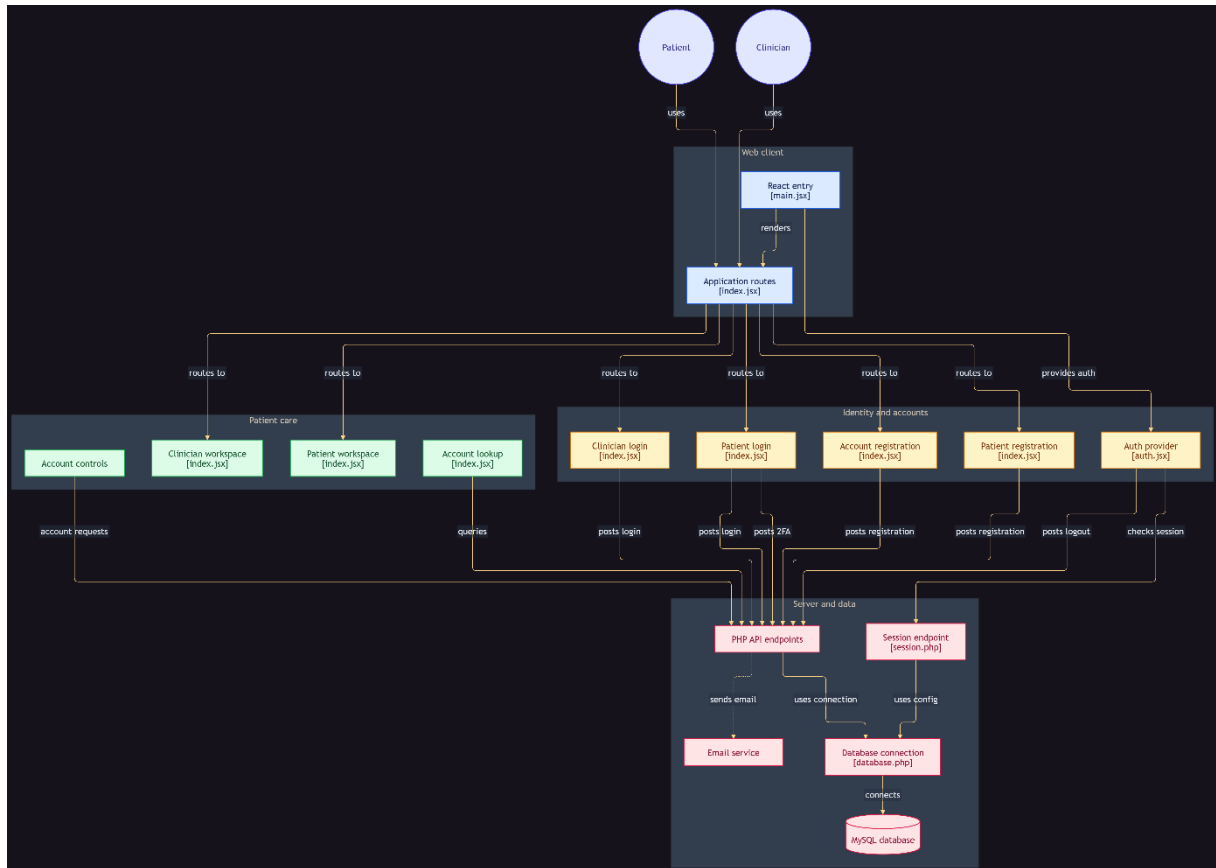
4.2 ESTRUTURA DE AUDITORIA

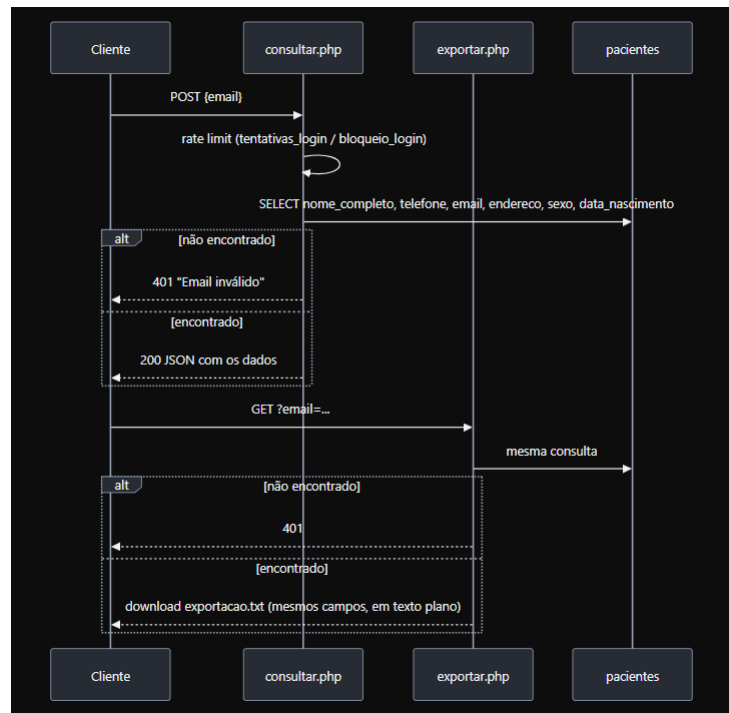
id	usuario_id	acao_realizada	tabela_afetada	data_hora	descricao	ip_address	user_agent
1	15	CADASTRO_PACIENTE_SUCESSO	pacientes	2026-09-25 04:44:58	Paciente leozao foi cadastrado com sucesso.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
2	15	LOGIN_FALHA	pacientes	2026-09-25 04:45:11	O paciente chamado leozao informou uma senha inválida.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
3	15	LOGIN_2FA	pacientes	2026-09-25 04:45:16	O usuário leozao iniciou o login e recebeu o código 2FA.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
4	15	2FA_SUCESSO	dados_pessoais	2026-09-25 04:45:33	O usuário leozao informou um código de verificação corretamente.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
5	15	LOGIN_SUCESSO	dados_pessoais	2026-09-25 04:45:33	O usuário leozao realizou login com sucesso.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
6	15	LOGIN_2FA	pacientes	2026-09-25 04:45:47	O usuário leozao iniciou o login e recebeu o código 2FA.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
7	15	2FA_FALHA	dados_pessoais	2026-09-25 04:45:55	O usuário leozao informou um código de verificação inválido.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
8	15	2FA_SUCESSO	dados_pessoais	2026-09-25 04:46:14	O usuário leozao informou um código de verificação corretamente.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
9	15	LOGIN_SUCESSO	dados_pessoais	2026-09-25 04:46:14	O usuário leozao realizou login com sucesso.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
10	15	LOGIN_2FA	pacientes	2026-09-25 04:49:54	O usuário leozao iniciou o login e recebeu o código 2FA.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36

5. DOCUMENTAÇÃO TÉCNICO-CIENTIFICA GERAL

5.1 VISÃO GERAL E ARQUITETURA



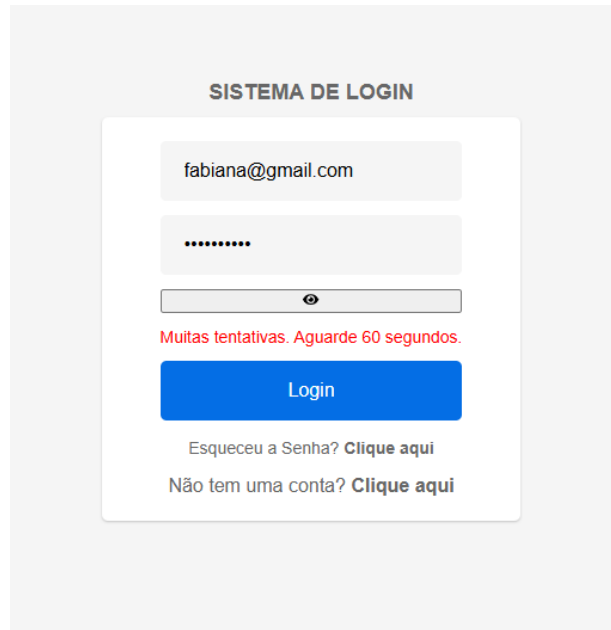




5.2 VALIDAÇÃO E TESTES

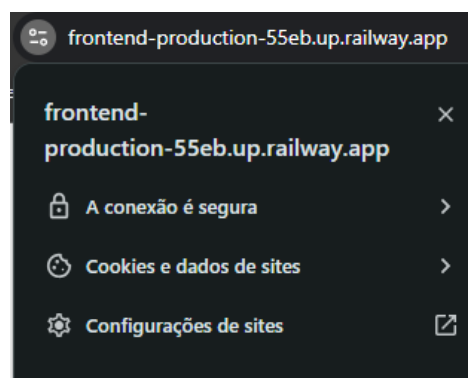
Para atestar a resiliência arquitetural do Projeto Continuum e garantir que as contramedidas estabelecidas no modelo STRIDE operam conforme o projetado, o sistema foi submetido a uma bateria de testes práticos. Esta subseção consolida a metodologia de avaliação e apresenta os resultados dos testes documentados, comprovando a eficácia dos controles de segurança e governança de dados.

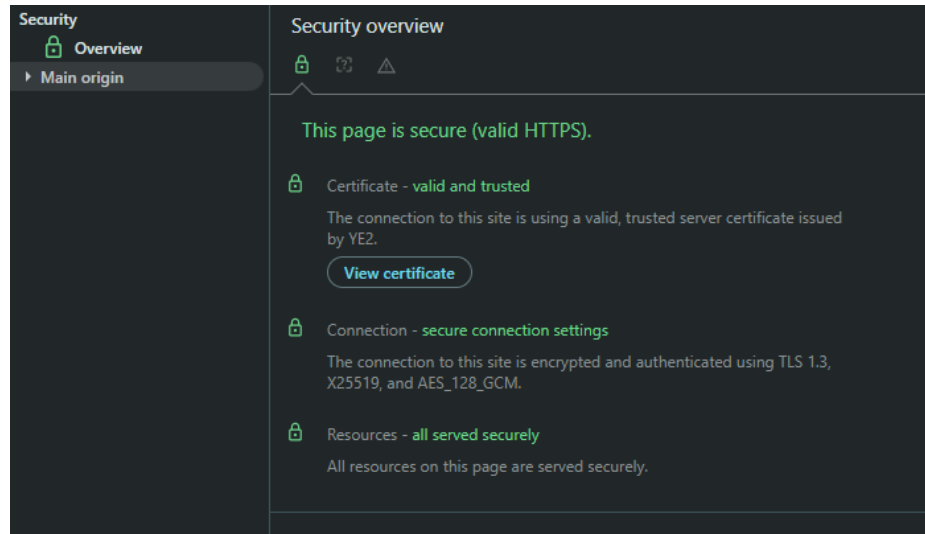
- A. Proteção contra Ataques de Força Bruta (Rate Limiting):** A aplicação foi testada contra tentativas repetidas de adivinhação de senhas. O script de autenticação foi configurado para tolerar um máximo de 5 (cinco) tentativas falhas consecutivas. No sexto erro, o sistema bloqueia o endereço/conta por 60 segundos, retornando o status HTTP 429 (Too Many Requests).



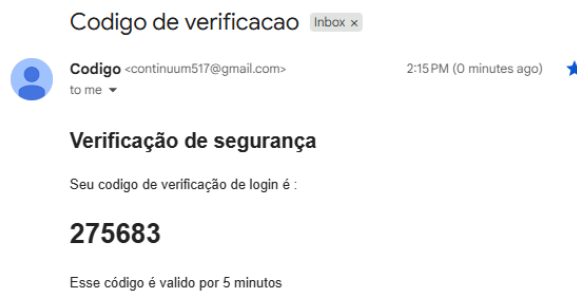
The image shows a login form titled "SISTEMA DE LOGIN". It contains two input fields: the first contains the email "fabiana@gmail.com" and the second contains masked characters ".....". Below the password field is a toggle switch for visibility, currently set to "off" (represented by an eye icon). A red error message "Muitas tentativas. Aguarde 60 segundos." is displayed below the toggle. A blue "Login" button is positioned below the error message. At the bottom of the form, there are two links: "Esqueceu a Senha? Clique aqui" and "Não tem uma conta? Clique aqui".

B. **Criptografia em Trânsito (TLS/HTTPS):** Para mitigar ameaças de interceptação de dados (Tampering/Sniffing), o tráfego da aplicação exige conexões criptografadas. O teste consistiu em interceptar as requisições de login e prontuário, validando a ausência de tráfego em texto claro. O trabalho inclui a evidência de tráfego cifrado, confirmando que as requisições trafegam sob o protocolo TLS seguro.





- C. **Validação do Duplo Fator de Autenticação (2FA) e Sessão:** O fluxo de 2FA foi testado para garantir que o código de 6 dígitos expira corretamente após 5 minutos e que a sessão principal só é liberada mediante o fornecimento da credencial correta. Tentativas de uso de tokens expirados foram devidamente rejeitadas pelo sistema, protegendo contra ataques de repetição (*Replay Attacks*).



- D. **Auditoria Imutável e Análise de Logs:** Em conformidade com os requisitos de responsabilização (*Accountability*), o sistema gera trilhas de auditoria para ações críticas. Apresenta-se abaixo um exemplo de análise de logs estruturado, evidenciando o funcionamento da tabela `logs_auditoria`, que opera de forma *append-only* no banco de dados. Os registros capturam o nível de severidade

(INFO, WARNING, SECURITY), a ação (ex: LOGIN_FALHA, 2FA_SUCESSO), o endereço IP e a data/hora.

id	usuario_id	acao	descricao	data_hora
1	35	LOGIN_2FA	O usuário leo iniciou o login e recebeu o código 2FA	2026-09-17 14:13:09
2	35	2FA_SUCESSO	O usuário leo informou um código de verificação corretamente.	2026-09-17 14:14:23
3	35	LOGIN_SUCESSO	O usuário leo realizou login com sucesso	2026-09-17 14:14:23

id	usuario_id	acao_realizada	tabela_afetada	request_id	severity	data_hora	descricao	ip_address	user_agent
1	15	CADASTRO_PACIENTE_SUCESSO	pacientes			2026-09-25 04:44:58	Paciente leozao foi cadastrado com sucesso.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
2	15	LOGIN_FALHA	pacientes		INFO	2026-09-25 04:45:11	O paciente chamado leozao informou uma senha inválida.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
3	15	LOGIN_2FA	pacientes		SECURITY	2026-09-25 04:45:16	O usuário leozao iniciou o login e recebeu o código 2FA.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
4	15	2FA_SUCESSO	dados_pessoais		INFO	2026-09-25 04:45:33	O usuário leozao informou um código de verificação corretamente.	:::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36

5.3 REFERENCIAL TEÓRICO

Para sustentar as decisões arquiteturais e as práticas de defesa adotadas no Projeto Continuum, a documentação baseia-se num enquadramento literário e legal robusto, essencial para o contexto crítico da saúde.

- Fundamentação Técnica e OWASP:** O desenvolvimento da plataforma faz o uso de artigos científicos e/ou normas técnicas alinhadas com as diretrizes globais de cibersegurança. As decisões de arquitetura fundamentam-se nas recomendações do **OWASP Top 10**. A adoção do algoritmo Argon2id para senhas e do AES-256 para dados em repouso segue o *OWASP Cryptographic Storage Cheat Sheet*, visando mitigar vulnerabilidades de *Cryptographic Failures* (A02:2021). Da mesma forma, as políticas de sessão segura e o bloqueio por Rate Limiting sustentam-se nas normas do OWASP para *Identification and Authentication Failures* (A07:2021).
- Normas Complementares:** Em paralelo, a estratégia de criptografia e gestão da segurança da informação é também justificada através das diretrizes do NIST (*National Institute of Standards and Technology*) e das normas da família ISO/IEC 27000.
- Base Legal e Governança:** A modelação do banco de dados e os fluxos de interface apoiam-se na literatura jurídica referente à Lei Geral de Proteção de Dados (Lei nº 13.709/2018), fundamentando a necessidade técnica de

minimização de dados e os mecanismos de recolha de consentimento (Art. 7º e Art. 11).

- **Normalização Académica:** Toda a literatura, incluindo os *frameworks* de segurança da OWASP, manuais e artigos consultados durante a construção do software, estão compilados numa secção bibliográfica final, apresentando as referências normalizadas de acordo com os padrões exigidos pela ABNT.